

GIAIMO Lucas, KASMI Wasim, SOLER Valentin

RGPD

Qu'est que le RGPD ?

1. Définition du RGPD

Le RGPD (Réglementation Générale sur la Protection des données) est un texte de loi européen encadrant l'utilisation, le stockage, le partage et la suppression des données personnelles. Le RGPD est entré en application le 25 mai 2018 dans tous les pays membres de l'union européenne. Son objectif principal est de protéger la vie privée des personnes et de leur donner davantage de contrôle sur les informations personnelles possédées par une société.

Le RGPD s'applique à toutes les organisations, publiques ou privées : entreprises, administrations, associations, écoles, hôpitaux ou simple site internet. Il concerne également les organisations situées hors union européenne dès lors qu'elles proposent des services à destination ou accessible par des utilisateurs européens. Par exemple, Google, étant américain, doit se plier au RGPD pour ses utilisateurs européens.

Une donnée personnelle correspond à toute information permettant d'identifier ou discriminer une personne, directement ou indirectement. Cela prend en compte le nom, le prénom, l'adresse, l'e-mail, le numéro de téléphone, l'IP, des informations ou même un historique de navigation d'un utilisateur. Le RGPD protège aussi les données sensibles des utilisateurs comme les informations médicales, les opinions politiques, les convictions religieuses ou les données biométriques.

Le règlement impose aussi une transparence sur le traitement des données faite par les entreprises: Le but de la collecte, la durée de conservation des données, le traitement des données est-elle faite par un tiers, le type de consentement donné par l'utilisateur (direct via un bouton d'acceptation par exemple) ainsi que les moyens mis en place pour la protection des données personnelles de l'utilisateur.

Le RGPD inclut aussi un droit d'accès, de modification, de suppression de ses données personnelles ainsi que l'opposition du traitement à des fins non essentielles au fonctionnement du service de l'utilisateur et le traitement par un tiers.

En France, la CNIL (commission nationale de l'informatique et des libertés) est chargée du respect de cette réglementation et de sanctionner les entreprises en infraction.

2. Données personnelles

Une donnée personnelle est toute information pouvant être reliée à une personne physique. Cette donnée peut lui être liée personnellement (son nom, son prénom par exemple) ou partagée avec d'autres individus mais pouvant quand même être reliée à l'utilisateur (sa ville, son âge ou son adresse IP par exemple).

Le regroupement de telles données peut être utilisé pour identifier l'utilisateur, que ce soit à des fins techniques ou marketing. En vertu du RGPD, le partage de ces informations avec des tiers ou leur utilisation à des fins étrangères au fonctionnement du service, sans le consentement explicite de l'utilisateur, est interdit.

3. Données sensibles

Une donnée sensible est une donnée personnelle révélant des informations très sensibles et intimes pouvant être utilisées pour nuire à l'utilisateur via de la discrimination quand cela touche à des données médicales ou du chantage quand l'information traite des pratiques ou de l'orientation sexuelle d'une personne. Le traitement de ses données est interdit hors nécessité, par exemple les données médicales d'un utilisateur peuvent être traitées par un cabinet médical dans le cadre d'un suivi patient.

4. Loi de la moindre donnée

La loi de la moindre donnée est le principe de minimisation des données collectées par une entreprise, comme dispose l'Article 5 Paragraphe 1 point c. du RGPD : "Les données doivent être : "adéquates, explicites et légitimes à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées". Par exemple, il n'est pas justifié la collecte de l'adresse postale d'un utilisateur pour son inscription à un service en ligne gratuit.

Le traitement de ces données doit aussi être explicitement indiqué et pour quelle finalité (Article 5 Paragraphe 1 point b.). L'utilisation de ladite donnée doit cesser dès lors que son utilisation n'est plus essentielle au service (Article 25), par exemple, une société peut demander à exploiter la géolocalisation d'un utilisateur durant une livraison, mais doit cesser son utilisation dès la livraison effectuée.

La conservation de ces données est aussi soumise à une limite définie par l'entreprise et qui ne peut dépasser sa nécessité de stockage légal ou pour le traitement de la part de l'entreprise (Article 5 Paragraphe 1 point e.)

5. Principe du consentement utilisateurs

Le consentement correspond à l'accord de l'utilisateur sur le traitement de ses données personnelles par une entreprise. Toutefois, il n'est pas obligatoire pour toute collecte ou tout traitement de données : lorsqu'il constitue la base légale du traitement, il doit, d'après l'article 4.11 du RGPD, être une manifestation de volonté "libre, spécifique, éclairée et univoque" du traitement de ses données. Cela peut être fait via une bannière avec un bouton d'acceptation et de refus. La preuve du consentement de l'utilisateur doit être conservée comme prévaut l'article 7.

Le retrait du consentement peut intervenir à tout moment de la part de l'utilisateur comme prévu par l'article 7.3 du RGPD : "La personne concernée a le droit de retirer son consentement à tout moment." Le retrait doit être aussi simple que l'acceptation pour l'utilisateur et sans aucune justification à donner. Le traitement des données de l'utilisateur doit cesser dès le retrait effectué.

Nous pouvons prendre comme exemple le bouton de désabonnement d'une newsletter, qui doit être visible, clair et fonctionnel. Cette désinscription vaut pour la fin d'utilisation des données personnelles.

6. Les différents droits de l'utilisateur.

L'utilisateur possède plusieurs droits vis-à-vis de ses données personnelles :

- **Droit de retrait du consentement** : L'utilisateur peut, à tout moment, demander l'arrêt du traitement de ses données personnelles comme prévoit l'article 7.3 du RGPD. Par exemple, cela est le cas lors de la désinscription d'une newsletter.
- **Droit d'accès** : L'utilisateur possède un droit de regard envers les informations possédées par une entreprise sur lui-même ainsi que le traitement effectué par l'entreprise et ses prestataires, comme prévoit l'article 15 du RGPD. Par exemple, un utilisateur peut demander à sa mutuelle toutes les données qu'elle possède ainsi que les prestataires traitant les données personnelles de l'utilisateur.
- **Droit de rectification** : L'utilisateur a le droit de modifier ses données personnelles possédées par une entreprise comme prévoit l'article 16 du RGPD. Par exemple, un utilisateur peut demander, après son déménagement, le changement de son adresse postale sur sa fiche client.
- **Droit à l'effacement ou à l'oubli** : L'utilisateur a le droit, grâce à l'article 17 du RGPD, de demander l'effacement total (hors information conservée pour des raisons légales) de ses données personnelles auprès d'une entreprise et de ses prestataires. Par exemple, à la fermeture d'un compte en banque,

l'utilisateur peut demander l'effacement total de ses données, mais la banque doit conserver les relevés de compte en banque pour une durée de 10 ans pour des raisons légales.

- **Droit à la portabilité** : Un utilisateur a le droit de demander de transférer ses données d'une entreprise vers une entreprise concurrente. Cela est garanti par l'article 20 du RGPD.
- **Droit d'opposition** : L'utilisateur, grâce à l'article 21, a le droit de s'opposer à tout traitement et partage de ses données personnelles. Par exemple, un utilisateur a le droit de s'opposer au démarchage de la part d'une entreprise.
- **Droit à la limitation de traitement** : Via l'article 18, un utilisateur a le droit de demander la non-utilisation d'une donnée personnelle de la part d'une entreprise. Par exemple, un élément d'un dossier RH semble erroné par l'employé.

JOB 2

Registre des traitements

ID	Traitement	Personnes concernées	Données	Finalité	Base légale	Conservation
T01	Gestion clients RetailCo	Clients	Identité, coordonnées, achats, préférences	Offres personnalisées, expérience client	Consentement	5 ans
T02	Suivi patients HealthMed	Patients	Identité, coordonnées, historique médical, prescriptions	Suivi traitements, rappels, conseils	Consentement explicite	10 ans
T03	Analyse usage EduLearn	Utilisateurs	Identifiants, email, parcours, résultats	Parcours, recommandations, suivi	Consentement	2 ans

ID	Solution	Mesures de sécurité	Risques / points de vigilance
T01	DataManage / AutoMail	Pseudonymisation, AES-256, MFA, RBAC	Gestion du consentement marketing
T02	DataManage	Pseudonymisation, AES-256, MFA, RBAC	Données de santé, accès, conservation
T03	DataManage / MarketInsight	Pseudonymisation, AES-256, MFA, RBAC	Consentement, conservation, analyse des données

Se poser les questions : QUI ? → QUOI ? → POURQUOI ? → COMMENT ? → COMBIEN DE TEMPS ? → QUI Y A ACCÈS ? → QUELS RISQUES ?

JOB 3

Une DPIA (analyse d'impact sur la protection des données) est un processus systématique obligatoire selon l'article 35 du RGPD pour évaluer et atténuer les risques liés au traitement des données personnelles sensibles ou à grande échelle. Elle implique de décrire l'activité de traitement, d'évaluer les mesures de sécurité, d'identifier les risques, de proposer des atténuations et de documenter l'ensemble du processus avec la collaboration du DPO, des équipes juridiques, informatiques et des parties prenantes. Bien que chronophage et nécessitant des ressources importantes, une DPIA offre des avantages majeurs : amélioration de la conformité au RGPD, réduction des risques de violation de données, renforcement de la confiance des clients et évitement d'amendes pouvant atteindre 20 millions d'euros ou 4% du chiffre d'affaires annuel.

PIA Joint dans le projet.

The screenshot displays the PIA (Privacy Impact Assessment) software interface. The interface is in French and shows a project for 'X-Corp'. It includes a sidebar with navigation options like 'VALIDATION', 'CONTEXTE', 'PRINCIPES FONDAMENTAUX', and 'RISQUES'. The main area displays a 'Validation' section with a 'Cartographie des risques' (Risk Map) showing a 2x2 matrix of risk levels (Gravité du risque vs. Vraisemblance du risque). The matrix has four quadrants: 'Maximale' (top-right, red), 'Importante' (top-left, orange), 'Limitée' (bottom-left, green), and 'Négligeable' (bottom-right, light green). Three data points are plotted: (A) in the 'Importante' quadrant, (B) in the 'Maximale' quadrant, and (C) in the 'Limitée' quadrant. The interface also includes a 'VERSIONS DU PIA' section on the right, an 'Impression et téléchargement' section, and a 'PIÈCES JOINTES' section at the bottom left.

JOB 4

Qu'est ce qu'une violation ?

2 conditions nécessaires

- L'entreprise à mis en œuvre le un traitement de données personnelles.
- Ces données ont fait l'objet d'une violation (perte de disponibilité, d'intégrité ou de confidentialité de données personnelles, de manière accidentelle ou illicite).

Les obligations en terme de violations de données personnelles

Pour les personnes concernées, la violation engendre :	aucun risque	un risque	un risque élevé
Documentation interne , dans le « registre des violations »	X	X	X
Notification à la CNIL , dans un délai maximal de 72h	-	X	X
Information des personnes concernées dans les meilleurs délais, hors cas particuliers	-	-	X

Que faire en cas de violation ?

Il faut documenter en interne l'incident en clarifiant ces points

- La nature de la violation
- Si possible, les catégories et le nombre approximatif de personnes concernées par la violation
- Les catégories et le nombre approximatif d'enregistrements de données à caractère personnel concernés;
- Décrire les conséquences probables de la violation de données ;
- Décrire les mesures prises ou que vous envisagez de prendre pour éviter que cet incident se reproduise ou atténuer les éventuelles conséquences négatives.

Attention ! L'entreprise doit notifier sa violation de donnée dans un délais de 72 heures sans quoi elle est menacée d'amendes supplémentaires

La CNIL propose une pré-notification de violation de données personnelles sur leur site <https://notifications.cnil.fr/notifications/index>

5 étapes pour finaliser votre notification

TYPE DE NOTIFICATION ORGANISME A PROPOS DE LA VIOLATION ACTIONS ENTREPRISES RÉCAPITULATIF

1 — 2 — 3 — 4 — 5

Type de notification

Les champs en caractères gras sont obligatoires

TYPE DE NOTIFICATION

Précisez si vous allez effectuer une notification complète, une notification initiale qui sera complétée ultérieurement ou si vous souhaitez compléter ou amender une notification déjà réalisée

☐ Notification complète

☒ Notification initiale

☐ Notification complémentaire / modifiée

Etape suivante

Organismes concernés par la violation

Les champs en caractères gras sont obligatoires

IDENTIFICATION DE L'ORGANISME

Número SIREN

☒ Cochez cette case si votre organisme ne dispose pas de N° SIREN

COORDONNÉES DE L'ORGANISME RESPONSABLE DE TRAITEMENT CONCERNÉ PAR LA VIOLATION

Dénomination	Adresse postale
X-corp	Paris, France
Número de TVA intracommunautaire	Code postal
	75000
☒ Absence de Numéro de TVA intracommunautaire	Ville
Secteur d'activité de l'organisme	Paris
Information et communication	☐ Pays non membre de l'Union européenne
Effectif	Pays
100 à 199 salariés	France

COORDONNÉES DU RESPONSABLE LÉGAL

Civilité

☒ Monsieur ☐ Madame ☐ Ne se prononce pas

Nom	Adresse électronique
DUPONT	duponjean@xcorp.fr
Prénom	Confirmer l'adresse électronique
Jean	duponjean@xcorp.

Nature de la violation

Les champs en caractères gras sont obligatoires

DATE DE LA VIOLATION

- ☐ La violation s'est étendue sur une période déterminée
- ☐ La violation est toujours en cours

Date approximative de la violation

Date et heure de prise de connaissance de la violation

Commentaires sur les dates

Si vous n'êtes pas sûr(e) de ces dates, indiquez-le ici.

Dans quelles circonstances avez-vous découvert la violation ?

A PROPOS DE LA VIOLATION

Nature de la violation

- ☐ Perte de la confidentialité
- ☐ Perte de l'intégrité
- ☐ Perte de la disponibilité

Descriptif détaillé de la violation

Merci de décrire ici l'incident, son origine, son déroulé, ses conséquences et tout élément nous permettant de comprendre la violation

Cause(s) de la violation

- ☐ Acte interne malveillant
- ☐ Acte interne accidentel
- ☐ Acte externe malveillant
- ☐ Acte externe accidentel
- ☐ Inconnu
- ☐ Autre

NATURE DES DONNÉES CONCERNÉES PAR LA VIOLATION

Nature et teneur des données personnelles concernées par la violation

- ☐ Etat civil (ex : nom, sexe, date de naissance, âge...)

☐ NIR (Numéro d'Inscription au Répertoire)

☐ Coordonnées (ex : adresse postale ou électronique, numéros de téléphone fixe ou portable...)

☐ Données d'identification ou d'accès (ex : identifiant, mot de passe, numéro client...)

☐ Données relatives à des informations financières (ex : revenus, numéro de carte de crédit, coordonnées bancaires), économiques

☐ Documents officiels (Passports, pièces d'identité, etc.)

☐ Données de localisation

☐ Données relatives à des infractions, condamnations, mesures de sûreté

☐ Les données concernées ne sont pas connues pour le moment

☐ La violation concerne d'autres données
- Données sensibles

☐ Origine raciale ou ethnique

☐ Opinions politiques

☐ Opinions philosophiques ou religieuses

☐ Appartenance syndicale

☐ Orientation sexuelle

☐ Données de santé

☐ Données biométriques

☐ Données génétiques

Origine(s) de l'incident

- ☐ Equipement perdu ou volé
- ☐ Papier perdu, volé ou laissé accessible dans un endroit non sécurisé
- ☐ Courrier perdu ou ouvert avant d'être retourné à l'expéditeur
- ☐ Piratage, logiciel malveillant (par exemple rançongiciel) et/ou hameçonnage
- ☐ Mise au rebut de documents papier contenant des données personnelles sans destruction physique
- ☐ Mise au rebut d'appareils numériques contenant des données personnelles sans effacement sécurisé
- ☐ Publication non volontaire d'informations
- ☐ Données de la mauvaise personne affichées sur le portail du client
- ☐ Données personnelles envoyées à un mauvais destinataire
- ☐ Informations personnelles divulguées de façon verbale
- ☐ Autre

Cause(s) de la violation

- ☐ Acte interne malveillant
- ☐ Acte interne accidentel
- ☐ Acte externe malveillant
- ☐ Acte externe accidentel
- ☐ Inconnu
- ☐ Autre

CATÉGORIES DE PERSONNES CONCERNÉES PAR LA VIOLATION

- ☐ Employés
- ☐ Utilisateurs
- ☐ Adhérents
- ☐ Etudiants / élèves
- ☐ Personnel Militaire
- ☐ Clients (actuels ou potentiels)
- ☐ Patients
- ☐ Mineurs
- ☐ Personnes vulnérables
- ☐ Pas déterminé pour le moment
- ☐ Autres

Nombre approximatif de personnes concernées par la violation

MESURES DE SÉCURITÉ PRÉALABLES À LA VIOLATION

Mesures de sécurité préalables à la violation

Par exemple : Les données étaient chiffrées à l'aide d'un algorithme de chiffrement réputé fort (AES), des sauvegardes étaient effectuées de manière journalière et mensuelle, les disques durs des ordinateurs portables sont chiffrés, etc.

Que va faire la CNIL ?

Dès réception, la CNIL va instruire la notification. La procédure relative à la violation notifiée pourra être clôturée si la CNIL constate que :

La violation ne porte pas atteinte aux données personnelles ou ne présente pas de risque pour les droits et libertés des personnes.

Vous avez correctement informé les personnes concernées.

Vous avez mis en place, préalablement à la violation, des mesures techniques de protection appropriées.

La CNIL pourra vous imposer d'informer les personnes concernées si elle constate que :

Vous ne les avez pas correctement informées.

Les mesures techniques de protection que vous avez mises en place préalablement à la violation ne sont pas appropriées.

Légalement, il est obligatoire de notifier la CNIL d'après l'article 33 du règlement général sur la protection des données.

JOB 5

Un audit de sécurité doit couvrir 4 grands domaines ;

la gouvernance (registre, DPO, durées de conservation)

- Un registre des traitements est tenu à jour Art. 30
- Chaque traitement a une finalité définie et documentée Art. 5(1)(b)
- Une base légale est identifiée pour chaque traitement Art. 6
- Un DPO est désigné (si obligatoire) et déclaré à la CNIL Art. 37-39
- Les durées de conservation sont définies et appliquées Art. 5(1)(e)
- Une procédure de purge ou d'archivage est en place Art. 5(1)(e)

la relation aux personnes (information, consentement, droits)

- Les mentions d'information sont présentes sur chaque point de collecte Art. 13
- Les mentions contiennent toutes les informations exigées (identité, finalités, base légale, durée, droits) Art. 13
- Les formulaires ne collectent que les données strictement nécessaires (minimisation) Art. 5(1)©
- Le consentement, lorsqu'il est la base légale, est recueilli par un acte positif clair (pas de case pré-cochée) Art. 7
- Le retrait du consentement est aussi simple que son recueil Art. 7(3)
- Les cookies et traceurs sont gérés conformément aux recommandations CNIL Directive ePrivacy

la chaîne de sous-traitance (contrats, garanties)

- Une procédure répond aux demandes de droit d'accès Art. 15
- Les demandes de rectification, effacement et portabilité sont traitées dans le délai d'un mois Art. 16-20
- Le droit d'opposition est respecté, notamment en prospection Art. 21
- Les décisions entièrement automatisées sont encadrées et signalées Art. 22

la sécurité (mesures techniques, violations, transferts, international)

- Les mesures techniques sont adaptées aux risques (chiffrement, pseudonymisation, contrôle d'accès) Art. 32
- Les accès sont limités aux seules personnes habilitées Art. 32(1)(b)
- Une procédure de notification de violation est en place (72 h) Art. 33-34
- Les sauvegardes et la continuité d'activité sont testées Art. 32(1)©
- Les employés sont sensibilisés à la protection des données Art. 39(1)(a)
- Les transferts hors UE sont identifiés Art. 44-49
- Un mécanisme de transfert valide est en place (adéquation, CCT 2021/914, etc.) Art. 46
- Les traitements à risque élevé sont identifiés Art. 35
- Une analyse d'impact (AIPD) est réalisée pour ces traitements Art. 35

Exemple sur X-Corp:

Première étape ;

Recenser l'ensemble des traitements de l'organisation

On a RetailCo, HealthMed, EduLearn, Data Manage, MarketInsight et AutoMail qui sont les services d'exploitation de X-Corp.

Pour chaque traitement, nous allons vérifier la conformité avec la législation en vigueur

Voici le registre des activités de X-Corp

Traitement	Données & Sensibilité	Finalité	Base légale	Qualité	Destinataires / ST	Conservation
<i>DataManage / RetailCo</i>	Identité, contacts, achats, profils	Ciblage publicitaire, fidélisation	Consentement	Sous-traitant	CloudSecure, AdBoost	5 ans post-contact (excessif)
<i>HealthMed - Suivi Patients</i>	Identité, historique médical, prescriptions	Rappels, suivi de santé, conseils	Consentement explicite (art. 9.2.a)	Sous-traitant	CloudSecure, X-corp (support)	10 ans (hors cadre standard)
<i>EduLearn - Analytics</i>	Identifiants, logs, notes/résultats	Amélioration parcours, reco de cours	Consentement	Sous-traitant	CloudSecure	2 ans post-utilisation
<i>MarketInsight (IA)</i>	Données comportementales agrégées / profils	Entraînement de modèles IA, prédictions	Non documentée	RT ou ST ?	Équipes R&D, AdBoost	Non définie

Pour chaque donnée ligne on vérifie que;

Les données que X-Corp traite sont nécessaires à son activités

Dans chaque ligne on peut voir les informations que X-corp traite sont cohérentes avec leurs marchés

X-Corp ne traite aucune donnée dite « sensible » ou, si c'est le cas, qu'elle a bien le droit de les traiter

Le problème remonté par X-Corp sur Auto-Mail prose problème est doit être corrigé au plus vite

seules les personnes habilitées ont accès aux données dont elles ont besoin

Utilisation de RBAC cohérent

vous ne conservez pas vos données au-delà de ce qui est nécessaire.

Des durées de conservation de 10 et 5 ans sont excessives, il faut obligatoirement les justifier. La politique de conservation des données doit être revue, beaucoup plus fréquemment, par exemple tous les semestres

MarketInSight

Les données présentes dans le document ne nous permettent pas de conclure mais on peut soupçonner un manquement dans la clarté de l'utilisation des données personnelles des clients qu'il sous-traite. Point qui est fondamental dans un Audit RGPD. La gestion des consentements n'est pas claire pour l'utilisateur qui ne pense pas donner son consentement pour des mails marketing.

Fuite de donnée

Après la fuite de donnée, faire un RETEX, mettre en place des politiques de sécurité renforcée (mise en place d'un SIEM par exemple).